

information to be transmitted, and types of safeguards available to protect information. Management should implement appropriate controls or, if they are not available, restrict the type of information that can be transmitted. When transmitting sensitive information over a public network, information should be encrypted to protect it from interception or eavesdropping. Techniques include secure e-mail protocols, sFTP, and secure sockets layer (SSL) certificates.

II.C.13(c) *Disposal of Information*

The institution should have appropriate disposal procedures for paper-based and electronic information.⁴⁰ Designating a single individual, department, or function to be responsible for disposal facilitates accountability and promotes compliance with disposal policies.

Policies should prohibit employees from discarding paper-based information containing sensitive information by using the same disposal system as regular garbage to avoid accidental disclosure. Many institutions shred paper-based media on-site while others use collection and disposal services to ensure the media are rendered unreadable and unlikely to be reconstructed. Institutions that contract with third-party service providers should conduct due diligence to ensure those third parties conduct adequate employee background checks and employ appropriate controls. Contracts with third-party disposal firms should address acceptable disposal procedures.

Electronic information and computer-based media present distinct disposal challenges. In addition to disk drives and other forms of storage, information frequently is contained in or on the memory of other devices (e.g., printers, fax machines, and cellphones). Residual data frequently remain on media, even after deletion. Because the data can be recovered, additional disposal techniques should be applied to devices containing sensitive data. Overwriting destroys data by replacing it with new, random data. Overwriting may be preferable when the media will be reused. To be effective, overwriting may have to be performed many times.

Another disposal technique is degaussing, which scrambles the data recorded on the media with powerful, varying magnetic fields. Physical destruction of the media can make the data unrecoverable. Data can sometimes be destroyed after overwriting. Management should determine the most effective method of disposal based on the type of information. Policies and procedures should address making data non-recoverable. The institution should base its disposal policies on the sensitivity of the information. Policies, procedures, and training should inform employees about what actions should be taken to securely dispose of computer-based media and protect the data from the risks of reconstruction. Management should log the disposal of sensitive media. Logs should record the party responsible for disposal, as well as the date, media type, hardware serial number, and method of disposal. In cases when such devices are rented, rather than owned, by the institution, media sanitization should be addressed contractually so that sensitive information is disposed of properly before returning equipment at the end of the rental period.

⁴⁰ See also Information Security Standards, section III.C.4., requiring each financial institution to develop, implement, and maintain, as part of its information security program, appropriate measures to properly dispose of “customer information” and “consumer information.”

II.C.13(d) *Transit of Physical Media*

Management should implement policies for maintaining the security of physical media (including backup tapes) containing sensitive information while in transit, including to off-site storage, or when shared with third parties. Policies should include the following:

- Contractual requirements that incorporate necessary risk-based controls.
- Restrictions on the carriers used.
- Procedures to verify the identity of couriers.
- Requirements for appropriate packaging to protect the media from damage.
- Use of adequate encryption of sensitive information recorded on media that is being physically transported.
- Tracking of shipments to provide early indications of loss or damage.
- Security reviews or independent security reports of receiving companies.
- Use of nondisclosure agreements for couriers and third parties.

II.C.13(e) *Rogue or Shadow IT*

Management should have policies explaining that employees should not and are not authorized to use unsanctioned or unapproved IT resources (e.g., online storage services, unapproved mobile device applications, and unapproved devices). Security awareness or information security training should include procedures for identifying and reporting shadow IT.

II.C.14 Supply Chain

The typical institution purchases a wide variety of hardware and software, which often is manufactured or developed internationally. In a supply chain attack, a threat source incorporates unidentified and harmful features into the purchased items before delivery. During the risk identification process, management should identify factors that may increase risk from supply chain attacks and respond with appropriate risk mitigations. An effective information security program seeks to limit the potential for harm through techniques tailored to specific acquisitions and services. Examples of techniques to mitigate the risk from such attacks include the following:

- Only making purchases through reputable sellers who demonstrate an ability to control their own supply chains.
- Purchasing hardware and software through third parties to shield the institution's identity.
- Reviewing hardware for anomalies.
- Using automated software testing and code reviews for software.
- Regularly reviewing the reliability of software and hardware items purchased through activity monitoring and evaluations by user groups.

II.C.15 Logical Security

Action Summary

Management should have an effective process to administer logical security access rights for the network, operating systems, applications, databases, and network devices, which should include the following:

- Assigning users and devices the access required to perform required functions.
- Updating access rights based on personnel or system changes.
- Reviewing users' access rights at an appropriate frequency based on the risk to the application or system.
- Designing appropriate acceptable-use policies and requiring users to agree to them.
- Controlling privileged access.
- Changing or disabling default user accounts and passwords.

System devices, programs, and data are system resources. Because users may access these resources through the institution's network, management should identify and restrict logical access to all system resources to the minimum required for legitimate and approved work activities, according to the principle of least privilege. Access beyond the minimum required for work to be performed exposes the institution's systems and information to a potential loss of confidentiality, integrity, and availability. The institution's logical security policy and procedures should address access rights and how those rights are to be administered. Management and system administrators should regularly evaluate information system access.

Logical user access rights administration consists of three processes:

- Enrolling new users to the system.
- Authorizing modifications to user access and deletions.
- Monitoring access rights granted to each user, including periodic review and validation of access rights.

The enrollment process establishes the user's identity and anticipated business needs for information and systems. Management should identify and evaluate all users, including new employees, IT outsourcing relationships, and contractors. The assignment of access rights is typically performed by the employee's manager and the application or data owners responsible for each accessed resource, with documented approval. The assignment of rights may also be established by the employee's role or group membership, which confers certain user access rights.

Management should have an authorization process to enable the employee's manager and the application or data owners to modify or delete existing user access rights to information and systems. The authorization process should include controls to verify that proper authorizations were granted or removed. Modifications to access rights should occur when an individual's business needs change. Job changes can result in an expansion, reduction, or deletion of needed

access rights. Job changes that could trigger a modification or deletion of access rights include transfers, mandatory leave, resignations, and terminations. The institution should promptly review, and modify as needed, access rights for all users who experience job changes, particularly those with privileged access, remote access privileges, and access to customer information.

As part of the user access rights monitoring process, management should perform regular reviews to validate user access. Reviews should test whether access rights continue to be appropriate or whether they should be modified or deleted. Management should review access rights on a schedule commensurate with risk.

Logical user access rights administration also constrains user activities through an acceptable use policy that details permitted system uses, user activities, and the consequences of noncompliance. Management should maintain an acceptable use policy, and employees should be required to acknowledge and agree in writing to the policy. When implemented correctly, an acceptable use policy is a key control for user awareness and administrative policing of system activities. Elements of an acceptable use policy can include the following:

- Specific access devices that can be used to access the network.
- Hardware and software changes the user can make to his or her access device.
- Purpose and scope of network activity.
- Permitted network services.
- Information that can or cannot be transmitted, and authorized transmission methods.
- Bans on attempts to break into accounts, crack passwords, or disrupt service.
- Responsibilities for secure operation.
- Consequences of noncompliance.

Authorization for privileged access should be tightly controlled. Privileged access refers to the ability to override system or application controls, and may include system administrator access. All individuals who are granted privileged access should have the appropriate training commensurate with the risk and complexity of the systems and information they access. Prudent practices for controlling privileged access include the following:

- Identifying each privilege associated with each system resource.
- Implementing a process to allocate privileges on a need-to-use or an event-by-event basis.
- Documenting the granting and extent of privileged access.
- Assigning privileges to a unique user ID apart from the one used for normal business use.
- Prohibiting shared privileged user accounts.
- Logging and independent monitoring of the use of privileged access.
- Reviewing, by an independent party, privileged access rights and allocations at appropriate intervals.

Access rights to new software and hardware present a different problem. Typically, hardware and software are shipped with default users and at least one default user has privileged access. Lists of default accounts and passwords are readily available and can enable anyone with access to the system to obtain privileged access. These passwords should be changed, and the accounts

should be disabled. Alternately, if these accounts are not disabled, access should be monitored closely.

II.C.15(a) *Operating System Access*

Access to the operating system and system utilities provide users with the authority to make fundamental changes to the system. System utilities are programs that perform repetitive functions, such as creating, deleting, changing, or copying files. System utilities also could include numerous types of system management software that can supplement operating system functionality by supporting common system tasks, such as security, system monitoring, or transaction processing.

Unauthorized access to the operating system and system utilities could result in significant financial and operational losses. System and security administrators should restrict and monitor privileged access to operating systems and system utilities. Many operating systems have integrated or third-party access control software, which is often essential to effective access control and can be used to integrate the security management of the operating system and applications. To prevent unauthorized access to or inappropriate activity on the operating system and system utilities, management should do the following:

- Implement effective user access to appropriately restrict system access for both users and applications and, depending on the sensitivity, extend protection at the program, file, record, or field level.
- Limit the number of employees with access to operating systems and grant only the minimum level of access required to perform job responsibilities.
- Restrict and log access to and activity on operating system parameters, system utilities (especially those with data-altering capabilities), and sensitive system resources (including files, programs, and processes), and supplement with additional security software, as necessary.
- Restrict operating system access to specific terminals in physically secure and monitored locations.
- Secure or remove external drives and portable media from system consoles, terminals, or personal computers (PC) running terminal emulations, residing outside of physically secure locations.
- Prohibit remote access to operating system and system utilities, where feasible, and, at a minimum, require strong authentication and encrypted sessions before allowing such remote access.
- Filter and review logs for potential security events and provide adequate reports and alerts.
- Independently monitor operating system access by user, terminal, date, and time of access.

II.C.15(b) *Application Access*

Sensitive or mission-critical applications should incorporate appropriate access controls that restrict which functions are available to users and other applications. These access controls allow authorized users and other applications to interface with related databases. Some security software programs integrate access control between the operating system and some applications.

Such software is useful when applications do not have their own access controls or when the institution uses security software instead of the application's native access controls. Management should understand the functionality and vulnerabilities of the application access control solutions and consider those issues in the risk management process.

Management should implement effective application access controls by doing the following:

- Implementing a robust authentication⁴¹ method consistent with the criticality and sensitivity of the application.
- Easing the administrative burden of managing application access rights by using group profiles. Managing access rights individually can lead to inconsistent or inappropriate access levels.
- Periodically reviewing and approving the application access assigned to users for appropriateness.
- Communicating and enforcing the responsibilities of programmers, security administrators, and application owners for maintaining effective application access control.
- Setting time-of-day or terminal limitations for some applications or for more sensitive functions within an application.
- Logging access and events, defining alerts for significant events, and developing processes to monitor and respond to anomalies and alerts.

II.C.15(c) Remote Access

Management should develop policies to ensure that remote access by employees, whether using institution or personally owned devices, is provided in a safe and sound manner. Such policies and procedures should define how the institution provides remote access and the controls necessary to offer remote access securely. Management should employ the following measures:

- Disable remote communications if no business need exists.
- Tightly control remote access through management approvals and subsequent audits.
- Implement robust controls over configurations at both ends of the remote connection to prevent potential malicious use.
- Log and monitor all remote access communications.
- Secure remote access devices.
- Restrict remote access during specific times.
- Limit the applications available for remote access.
- Use robust authentication methods for access and encryption to secure communications.

There are several methods to provide remote access to employees. A prevalent form of remote access is through a VPN, which provides employees with a remote connection to the institution's network through a secure channel. The VPN connection uses public telecommunication infrastructure, such as the Internet, to provide remote offices or individual users with secure

⁴¹ Stronger authentication and layered security methods, such as the use of tokens, public-key infrastructure-based systems, or out-of-band verification coupled with a robust identity and access management process, can reduce the potential for unauthorized access.

access to their organization's network. VPN provides an encrypted isolated “tunnel” or connection between a remote user’s computer and the internal network.

Because VPN connections provide access to sensitive internal networks, the connections require additional authentication from the remote user. Use of physical token devices is a common method that can provide one-time passwords to strongly authenticate remote users.

While VPNs effectively connect the remote computer to the internal network, other alternatives provide virtual desktop capability. In these cases, the remote computer connects to a special purpose software system (sometimes a website), authenticates the user, and establishes a secure connection to an internal network server. That server establishes a local internal network desktop session and connects it to the screen, keyboard, mouse, and speakers of the remote computer. This is an actual remote control environment, where the remote user’s actions have the same effect as if connected to an actual internal network desktop. The remote control configuration may permit file transfer between the remote and internal computers. If the remote access method allows users to store sensitive institution information, management should consider limiting this access to institution-owned devices.

Other methods of remote access are available, including remote control software and third-party services, file transfer software (e.g., FTP), conferencing/session sharing tools, and other remote desktop software. Management should conduct a risk assessment and implement appropriate controls before adopting any remote access solution.

If the institution allows employees to use authorized remote access methods with institution-owned devices, management should implement the following mitigating controls:

- Prevent users from installing software on the devices.
- Prohibit users from having administrative privileges on the devices.
- Use firewalls, host-based IDS, and packet content filtering to identify, monitor, and limit remote access activities.

II.C.15(d) *Use of Remote Devices*

Management may choose to allow employees to connect remotely to the institution’s network using either an institution-owned or a personally owned device (often referred to as BYOD or “bring your own device”). Institution-owned devices are easier to secure because the institution controls the devices’ configuration and often can implement remote wiping if the devices are lost or stolen. It may be more difficult to implement remote wiping or a similar measure on an employee’s personally owned device. BYOD is becoming more popular, however, with institutions and employees because it reduces costs to the institution and enables employees to carry one device instead of two.

For all remote devices, management should do the following to control employee remote access to the institution’s network:

- Disallow remote access unless a compelling business justification exists.

- Require management approval of employee remote access.
- Regularly review remote access approvals and rescind those that no longer have a compelling business justification.
- Restrict remote access to authorized network areas and applications by using VLANs, permissions, and other techniques.
- Log remote access communications (including date, time, user, user location, duration, and activity), analyze logs in a timely manner, and follow up on anomalies.
- Implement robust authentication methods for remote access.
- Use encryption to protect communications between the access device and the institution.
- Use application white-listing.⁴²

For institution-owned devices, the institution should have the ability to manage the remote devices. The following controls should be implemented:

- Securely configure remote access devices.
- Protect remote access devices against malware.
- Patch, update, and maintain all software on remote access devices.
- Encrypt sensitive data residing on the access device.
- Implement secure containers with internal boundaries to store sensitive information, in a way that is not accessible to the device without permission.
- Periodically audit the access device configurations and patch levels.
- Remotely disable or wipe the device in the event of theft or loss.
- Use geolocation of the device to support device recovery efforts.

For personally owned devices, the institution may not have the ability to configure the devices; therefore, management should have an effective method or solution to ensure that such devices meet defined institution security standards, such as operating system version, patch levels, and anti-malware solutions, before such devices are allowed to log on to the network.

II.C.16 Customer Remote Access to Financial Services

Action Summary

Management should do the following:

- Develop and maintain policies and procedures to securely offer and strengthen the resilience of remote financial services, if the institution offers such services.
- Plan for actions that adversely affect the availability of remote banking services to customers.
- Coordinate appropriate responses with the institution's ISPs and third-party service providers.
- Regularly test the institution's response plans.

⁴² Application white-listing is the maintenance and use of a list of applications and their components (e.g., libraries and configuration files) that are authorized to be present or active on a system according to a well-defined baseline.

Institutions increasingly offer services to customers through remotely accessible technology, such as the Internet and mobile financial services. If the institution offers such services, management should implement appropriate authentication techniques⁴³ commensurate with the risk from remote banking activities. Beyond authentication, remote access controls should include additional layered security controls and may include some combination of the following:

- Application time-outs with mandatory re-authentication.
- Fraud detection and monitoring systems that include consideration of customer history and behavior to alert management, and enable a timely and effective institution response.
- Dual customer authorization through different access devices.
- Out-of-band⁴⁴ verification for transactions.
- Positive pay,⁴⁵ debit blocks, and other techniques to appropriately limit the transactional use of the account.
- Supplementary controls over certain account activities, such as transaction value limits, restrictions on devices for adding payment recipients, limits on the number of transactions allowed per day, and allowable payment windows (e.g., days and times).
- Reputation-based tools to block connections to the institution's servers based on device or network indicators known or suspected to be associated with fraudulent activities.
- Device authentication with appropriate enrollment and de-enrollment processes.
- Policies for addressing customer devices identified as potentially compromised and identifying customers who may be facilitating fraud.
- Controls over changes to account maintenance activities (e.g., address or password changes) performed by customers either online or through customer service channels.
- Supplementary controls for system administrators who are granted privileges to set up or change system configurations of business accounts.⁴⁶
- Customer education to increase awareness of the fraud risk and effective techniques customers can use to mitigate the risk.

Institution customers may also use e-mail or other electronic means to transmit instructions. All instructions received through such channels should be authenticated and validated in accordance with institution policies.

An area of heightened concern when financial institutions offer remote financial services is the potential for malicious activity against the institution's mobile or online services. Malicious actors may restrict availability to those services through denial of service (DOS) attacks that target the institution's ISPs, third-party service providers, infrastructure, or applications.

⁴³ Techniques include multiple factor authentication, device authentication, location consistency, and additional authentication for sensitive functions.

⁴⁴ Out-of-band refers to activity outside of the primary means of interfacing with the customer. For example, if a user is performing activity online, he or she may be authenticated through a one-time password sent via text message.

⁴⁵ Positive pay is a technique that can reduce check fraud by requesting businesses to send electronic files of information to the financial institution on all checks the business has issued.

⁴⁶ Refer to the FFIEC's ["Supplement to Authentication in an Internet Banking Environment."](#)

Additionally, attacks on organizations that share infrastructure with the institution, including domain name services, may adversely affect the availability of remote services. Management should develop and maintain policies and procedures to identify, measure, mitigate, monitor, and report on significant security incidents to ensure the resilience of remote financial services. Planning and coordination by the institution and its third-party service providers may improve the resilience of services in the face of those attacks. To prevent or minimize exposure to these incidents, management should do the following:

- Monitor threat alerts.
- Monitor service availability and diagnose causes of reduced availability.
- Monitor applications and network traffic for indicators of nefarious activity.
- Ensure traffic filtering by the institution's ISP or upstream ISP,⁴⁷ third-party service providers, and internal resources.
- Design and implement applications to withstand application-level DOS.
- Utilize distributed architecture.
- Limit traffic (e.g., allow valid traffic and block known bad traffic by port or IP address).
- Add bandwidth.
- Enable access to services through alternative channels.

The institution should develop and test an incident response plan in conjunction with the institution's ISPs and third-party service providers to mitigate the interruption of mobile or remote financial services. Refer to the "Incident Response" section of this booklet for more information.

Customers may be provided with a website disclosure with the institution's customer acceptable-use policy. Depending on the nature of the website, the institution may require customers to demonstrate knowledge of and agreement to abide by the terms of the acceptable use policy. That evidence can be paper-based or electronic.

Refer to appendix E⁴⁸ of the *IT Handbook's* "Retail Payment Systems" booklet for more information about mobile financial services.

II.C.16(a) Customer Awareness

The institution's customer awareness and education efforts should consider both retail and commercial account holders and include the following elements:

- An explanation of protections provided, and not provided, to account holders relative to electronic funds transfers under Regulation E, and a related explanation of the applicability of Regulation E to the types of accounts accessible online.

⁴⁷ An upstream ISP is usually a large ISP that provides Internet access to a local ISP.

⁴⁸ See the *IT Handbook's* "Retail Payment Systems" booklet, appendix E, "[Mobile Financial Services](#)."